

安全与信任白皮书（简版）

安全与信任白皮书（简版）

Executive Summary (EN): Nova SaaS isolates tenants, stores files in per-user cloud hubs, uses JWT auth and tool permission gates, and audits usage—user-readable trust story without raw error dumps.

写给谁

- 企业市场 / IT 采购
- 需要「能讲清楚安全」的销售与售前

不是渗透测试报告；细节审计见 [docs/brand-security-audit.md](#)。

1. 多租户隔离

项	说明
租户边界	注册用户 <code>tenant-{username}</code> ，项目与文件互不可见
云端路径	<code>cloud-storage/users/{userId}/workspaces/{uuid}/</code>
跨租户访问	路径校验拒绝 <code>tenant_forbidden</code>
侧栏项目	仅展示用户自建项目，系统枢纽不对用户暴露

一句话：每个客户一个院子，不是大杂院合租。

2. 身份与访问

项	说明
登录	JWT，SaaS 模式强制鉴权
注册	图形验证码（Redis），防机器刷号
管理端	平台管理员与租户用户分权
公网前	必须修改默认管理员密码

工具权限	白名单与设置内管控，非对话生态内展示
工作区沙箱	Always-On 与引擎级沙箱叙事
文件变更	SaaS 普通用户文件 Tab 只读；管理员可控
错误展示	温和灰提示，不中断 workflow；技术细节折叠

诚实边界：高强度代码执行场景建议私有部署 + 网络隔离；公网 SaaS 持续硬化沙箱。

4. 数据与隐私

项	说明
对话与文件	租户项目目录 + 云端枢纽
控制面	PostgreSQL（推荐）或 SQLite 开发
遥测	默认关闭策略（见安全审计）
私有部署	数据不出客户边界

5. 用量与审计

- 前台 **用量** 页：本人消耗与节省（路由叙事）
- 后台：**AI 用量** 大盘（管理员）
- 计费意图：订阅 + 积分，算力可追踪

6. 用户可感知的「安心」设计

- 成果可预览、可下载、可定位文件夹——**透明交付**
- 断线不伪造「思考中」；恢复自动进行
- 权限提示去红，不恐慌

7. 与竞品话术

「我们不只是聊天加密，而是从**租户、文件、工具执行、用量**四层关进院子。」

相关文档

- [部署与运维叙事](#)
- [风险与合规摘要](#)
- [单机版与 SaaS 对照](#)

